TravelShield AI - Executive Security Report

Synthetic demonstration environment. Findings do not describe any real TBO system.

Generated 2026-11-07T20:15:38+00:00. 18 findings, 0 verified, 1 resolved.

ID	Pri	Score	Status	Title
TS-0003	P1	10.0	Resolved	Cross-agency booking access
TS-0005	P1	10.0	Reopened	Unauthorized refund of another agency's booking
TS-0001	P1	8.9	Reopened	Undocumented debug endpoint exposes configuration
TS-0002	P1	8.9	Reopened	Legacy bookings list readable without authentication
TS-0004	P1	8.5	Reopened	Booking fare modifiable through client-supplied fields
TS-0006	P2	8.1	Reopened	Template expression evaluated in greeting parameter
TS-0008	P2	8.1	Reopened	Preview endpoint fetches internal URLs
TS-0009	P2	8.1	Reopened	Shell metacharacters change the behavior of the ping to
TS-0011	P2	8.1	Reopened	Query operator in booking search returns another agency
TS-0007	P2	7.3	Reopened	Quote characters trigger a database error on flight sea
TS-0010	P2	7.3	Reopened	Session token still valid after logout
TS-0014	P3	5.4	Reopened	Booking response exposes internal cost and unmasked pas
TS-0016	P3	5.4	Reopened	Line breaks accepted in a response header value
TS-0017	P3	5.4	Reopened	Redirect endpoint sends users to arbitrary external URL
TS-0018	P3	5.4	Reopened	Login accepts unlimited failed attempts
TS-0012	P3	5.1	Reopened	Coupon can be applied repeatedly
TS-0013	P3	4.9	Reopened	Executable file types accepted by document upload
TS-0015	P3	2.7	Reopened	Malformed booking id returns an internal stack trace

TS-0003: Cross-agency booking access

Endpoint GET /bookings/{booking_id} | workflow booking_detail | severity critical
Remediation: Enforce booking.agency == caller.agency (object-level authorization) on every booking route.

TS-0005: Unauthorized refund of another agency's booking

Endpoint POST /bookings/{booking_id}/refund | workflow refund_processing | severity critical
Remediation: Require finance/admin role AND booking ownership; reject repeat refunds and amounts above fare.

TS-0001: Undocumented debug endpoint exposes configuration

Endpoint GET /api/internal/debug/config | workflow platform_configuration | severity high
Remediation: Remove the debug route from deployed builds; inventory it if it must exist.

TS-0002: Legacy bookings list readable without authentication

Endpoint GET /api/v0/legacy/bookings | workflow booking_detail | severity high

Remediation: Decommission /api/v0/legacy/bookings or require authentication and agency scoping.

TS-0004: Booking fare modifiable through client-supplied fields

Endpoint POST /bookings/{booking_id}/modify | workflow booking_modification | severity high
Remediation: Bind input to an explicit schema (seat, passenger) and reject unknown fields.

TS-0006: Template expression evaluated in greeting parameter

Endpoint GET /agency/greeting | workflow agency_account_management | severity high
Remediation: Render user input as data; escape it; never pass it to a template engine as a template.

TS-0008: Preview endpoint fetches internal URLs

Endpoint GET /preview | workflow platform_tools | severity high
Remediation: Allowlist outbound hosts, resolve and block private ranges, never return raw upstream bodies.

TS-0009: Shell metacharacters change the behavior of the ping tool

Endpoint GET /tools/ping | workflow platform_tools | severity high
Remediation: Validate hostnames against a strict pattern and never build shell command lines from input.

TS-0011: Query operator in booking search returns another agency's bookings

Endpoint POST /bookings/search | workflow booking_search | severity high
Remediation: Reject non-string filter values and always scope the query to the caller's agency.

TS-0007: Quote characters trigger a database error on flight search

Endpoint GET /flights/search | workflow flight_search | severity high
Remediation: Validate airport codes and use parameterized queries.

TS-0010: Session token still valid after logout

Endpoint POST /auth/logout | workflow login | severity high
Remediation: Revoke server-side session state on logout and on role or password change.

TS-0014: Booking response exposes internal cost and unmasked passport

Endpoint GET /bookings/{booking_id} | workflow booking_detail | severity medium
Remediation: Use a response model that omits internal fields and masks identifiers.

TS-0016: Line breaks accepted in a response header value

Endpoint GET /export | workflow reporting | severity medium
Remediation: Reject control characters in any value reflected into headers.

TS-0017: Redirect endpoint sends users to arbitrary external URLs

Endpoint GET /redirect | workflow navigation | severity medium
Remediation: Accept only relative paths or an allowlist of destinations.

TS-0018: Login accepts unlimited failed attempts

Endpoint POST /auth/login | workflow login | severity medium
Remediation: Throttle and lock out repeated failed logins per account and per source.

TS-0012: Coupon can be applied repeatedly

Endpoint POST /coupons/apply | workflow coupon_application | severity medium
Remediation: Record redeemed codes per booking and reject repeats server-side.

TS-0013: Executable file types accepted by document upload

Endpoint POST /documents/upload | workflow document_management | severity medium
Remediation: Allowlist extensions and MIME types, cap size, store outside the web root.

TS-0015: Malformed booking id returns an internal stack trace

Endpoint GET /bookings/{booking_id} | workflow booking_detail | severity low
Remediation: Return generic errors to clients and log details server-side.